CYS 410: SECURITY AND RISK MANAGEMENT PRACTICES

MS. NANYANGWE L.R

nanyangweleah@gmail.com

0967203891 (WHATSAPP)

6. PRINCIPLES OF MANAGEMENT

- Effective management principles are crucial for ensuring that security policies, leadership practices, and governance structures align with the organization's overall strategy. This helps in securing information systems, protecting data, and maintaining compliance with regulations.
- Security policies and frameworks
- Leadership in security management
- IT governance and compliance

1. SECURITY POLICIES AND FRAMEWORKS

- Security policies and frameworks are foundational elements in managing organizational security, providing guidance on implementing, assessing, and maintaining security measures.

A. SECURITY POLICIES

- Definition: A security policy is a set of rules and guidelines that dictate how an organization should protect its digital and physical assets.
- Purpose: These policies help to:
  - Ensure consistency in decision-making related to security.
  - Define acceptable use of IT resources.
  - Provide a structure for addressing security breaches.

A. SECURITY POLICIES…

- **Key Policies:**
  - **Access Control Policies:** Dictate who has access to systems and data and under what circumstances.
  - **Incident Response Policies:** Define the procedures to follow when a security breach occurs.
  - **Data Protection and Privacy Policies:** Focus on safeguarding sensitive data, ensuring compliance with privacy regulations (e.g., GDPR).
  - **Disaster Recovery and Business Continuity Plans:** Ensure that the organization can recover from disasters and continue operations with minimal disruptions.

B. SECURITY FRAMEWORKS

- Definition: A security framework provides a structured approach for establishing, managing, and improving security.

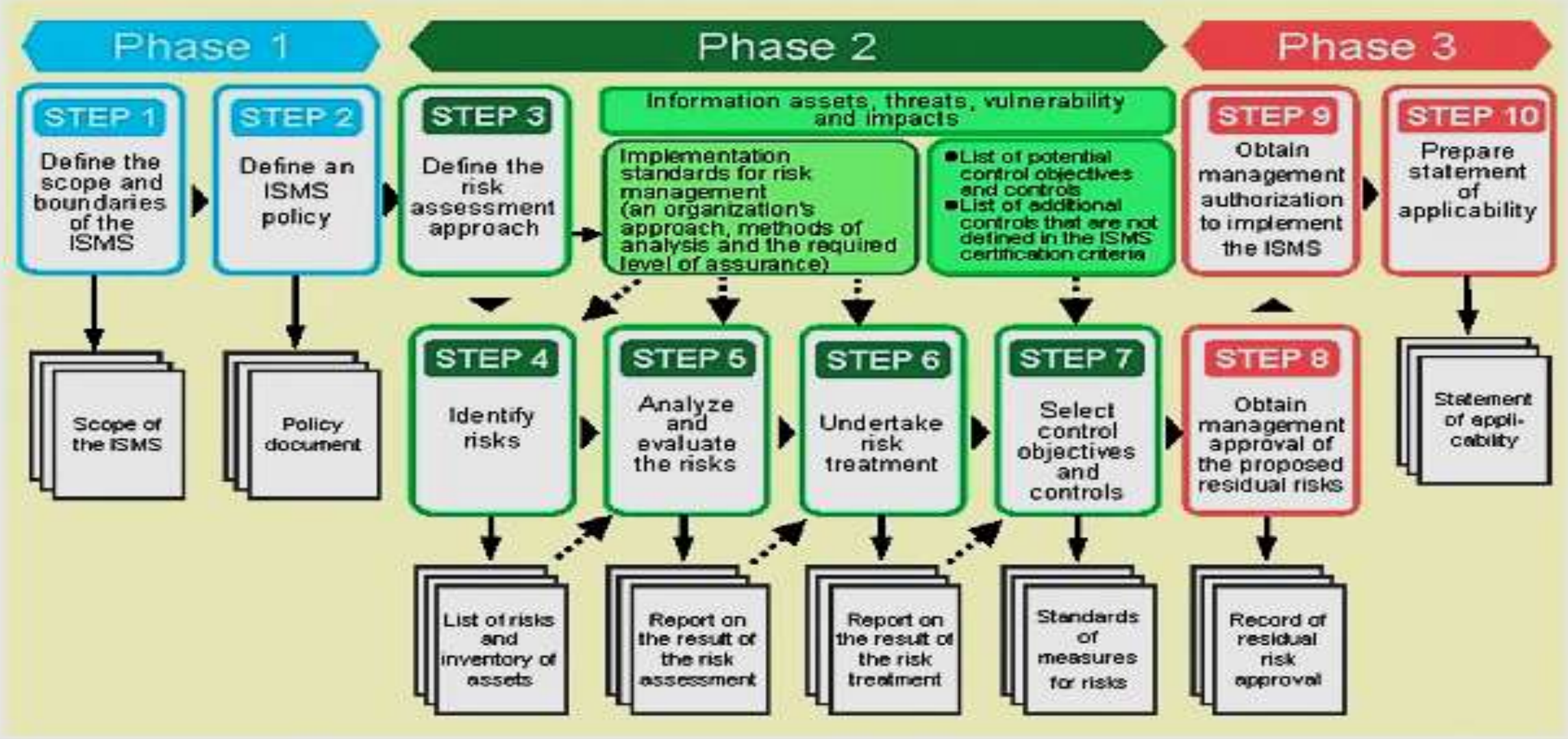
B. SECURITY FRAMEWORKS…

- Common Security Frameworks:
  - **ISO/IEC 27001 (International Organization for Standardization) and IEC (International Electrotechnical Commission):** A widely adopted standard for information security management systems (ISMS), outlining how to secure information assets.
  - **NIST Cybersecurity Framework:** Provides guidelines for managing and reducing cybersecurity risk, including identifying, protecting, detecting, responding, and recovering from incidents.
  - **COBIT (Control Objectives for Information and Related Technologies):** A framework for IT governance and management, focusing on security and risk management.

BENEFITS OF ISO/IEC 27001

- Resilience to cyber-attacks
- Preparedness for new threats
- Data integrity, confidentiality and availability
- Security across all supports
- Organization-wide protection
- Cost savings

ISO 27001 Management Framework



HOW CAN ORGANIZATIONS IMPLEMENT THE ISO 27001 CYBERSECURITY FRAMEWORK?

- The implementation process for the ISO 27001 Cybersecurity Framework PDF involves several key steps:
  - **Conduct a risk assessment:** Identify and assess potential risks and vulnerabilities to the organization's information systems.
  - **Develop an information security policy:** Create a comprehensive policy that outlines the organization's commitment to information security and sets clear objectives.

HOW CAN ORGANIZATIONS IMPLEMENT THE ISO 27001 CYBERSECURITY FRAMEWORK PDF?...

- **Implement controls:** Define and implement appropriate security controls based on the identified risks and the ISO 27001 standard requirements.
- **Monitor and review:** Continually monitor and review the effectiveness of the implemented controls, ensuring they meet the organization's security objectives.
- **Conduct regular audits:** Perform internal and external audits to assess compliance with the ISO 27001 framework and identify areas for improvement.

2. LEADERSHIP IN SECURITY MANAGEMENT

- Strong leadership in security management ensures that security practices are integrated into the organizational culture, and security professionals can effectively address emerging threats.

A. ROLE OF SECURITY LEADERSHIP

- **Setting Vision and Strategy:** Security leaders, such as Chief Information Security Officers (CISOs), define the organization's security vision, aligning it with business goals.
- **Building a Security Culture:** Promote an organizational culture where security is a top priority, ensuring that all employees understand their roles in maintaining security.
- **Decision Making:** Security leaders must make critical decisions regarding resource allocation, risk management, and policy enforcement.
- **Stakeholder Engagement:** Engage with internal and external stakeholders to ensure buy-in for security initiatives and manage the organization's security posture effectively.

B. KEY SKILLS FOR SECURITY LEADERSHIP

- **Strategic Thinking**: The ability to anticipate security risks and plan long-term strategies.
- **Communication**: Effective communication skills to convey security concerns and decisions to both technical and non-technical stakeholders.
- **Risk Management**: Understanding risk management principles to make informed decisions that minimize security risks.
- **Crisis Management**: Leading the organization through security incidents and ensuring timely and effective responses.

3. IT GOVERNANCE AND COMPLIANCE

- IT governance and compliance ensure that an organization’s IT infrastructure is well-managed, aligned with business objectives, and adheres to relevant regulations.

A. IT GOVERNANCE

- **Definition**: IT governance involves the structures, processes, and policies that ensure that IT supports the organization’s goals while minimizing risks.

A. IT GOVERNANCE….

- **Key Components**:
  - **Strategic Alignment**: Ensures that IT investments and initiatives align with the organization's overall strategy and business goals.
  - **Value Delivery**: Focuses on ensuring that IT projects and investments deliver value to the organization.
  - **Risk Management**: Identifies, assesses, and mitigates risks related to IT systems and data.
  - **Performance Measurement**: Implements measures to assess the effectiveness and efficiency of IT services and security programs.

B. IT COMPLIANCE

- **Definition**: IT compliance refers to adhering to external regulations, industry standards, and internal policies to ensure the organization operates within the legal and ethical boundaries.

B. IT COMPLIANCE…

- **Common Compliance Standards**:
  - **GDPR (General Data Protection Regulation)**: Requires organizations to protect personal data and maintain privacy for individuals.
  - **HIPAA (Health Insurance Portability and Accountability Act)**: Governs the security and privacy of health-related data.
  - **SOX (Sarbanes-Oxley Act)**: Enforces corporate responsibility and governance, focusing on financial transparency and the integrity of business operations.
  - **PCI DSS (Payment Card Industry Data Security Standard)**: Sets security standards for companies that handle credit card information.

C. ROLE OF COMPLIANCE IN SECURITY

- **Data Protection**: Ensures that sensitive data is adequately protected according to legal and regulatory standards.
- **Audit and Monitoring**: Regular audits and continuous monitoring help assess compliance levels and identify gaps in security and governance.
- **Penalties for Non-compliance**: Failure to comply with laws and regulations can result in hefty fines, lawsuits, and reputational damage.

7. PHYSICAL SECURITY MANAGEMENT

- Physical security management is a critical component of an organization's overall security strategy, focusing on protecting assets, personnel, and infrastructure from unauthorized access, theft, vandalism, and natural disasters. It involves implementing measures such as access control, surveillance, and disaster recovery planning to mitigate security risks.
- Access control and perimeter security
- Surveillance and monitoring
- Disaster recovery and contingency planning

ACCESS CONTROL AND PERIMETER SECURITY

- Access control and perimeter security are the first lines of defence against unauthorized access and intrusions.

A. ACCESS CONTROL

- Access control refers to the mechanisms used to regulate who can enter or use specific areas or resources within an organization.

TYPES OF ACCESS CONTROL

1. **Physical Access Control**
   - **Locks and Keys**: Traditional security methods to restrict entry to authorized personnel only.
   - **Smart Card & RFID Systems**: Employees use badges or cards with embedded chips to gain entry.
   - **Biometric Authentication**: Uses fingerprints, iris scans, or facial recognition for enhanced security.
   - **PIN and Password Systems**: Users must enter a predefined code to access secured areas.

TYPES OF ACCESS CONTROL…

2. **Logical Access Control**
   - **Two-Factor Authentication (2FA)**: Combines a password with an additional verification method, like a mobile OTP.
   - **Role-Based Access Control (RBAC)**: Grants access based on job roles and responsibilities.
3. **Network Access Control (NAC)**
   - Ensures that only authorized devices and users can connect to an organization's network.

B. PERIMETER SECURITY

- Perimeter security protects the outer boundaries of a facility or organization from unauthorized access and threats.

KEY PERIMETER SECURITY MEASURES

- **Fencing and Barriers**: Prevents intruders from physically entering restricted areas.
- **Security Guards and Patrols**: Provides human surveillance and rapid response to security incidents.
- **Turnstiles and Gates**: Controls pedestrian and vehicle access points.
- **Lighting and Motion Sensors**: Enhances visibility and detects unauthorized movement.

2. SURVEILLANCE AND MONITORING

- Surveillance and monitoring are essential for detecting security threats, tracking movement, and ensuring compliance with security policies.

TYPES OF SURVEILLANCE AND MONITORING

- **A. Security Cameras (CCTV)**
  - **Fixed Cameras**: Monitor specific areas continuously.
  - **Pan-Tilt-Zoom (PTZ) Cameras**: Allow remote operators to adjust the camera's angle and zoom.
  - **Infrared (Night Vision) Cameras**: Used for monitoring in low-light conditions.
  - **Facial Recognition Cameras**: Identify individuals based on biometric features.

TYPES OF SURVEILLANCE AND MONITORING…

- **B. Intrusion Detection Systems (IDS)**
  - **Motion Sensors**: Detect movement in restricted areas and trigger alarms.
  - **Glass Break Detectors**: Identify the sound of breaking glass to prevent forced entry.
  - **Vibration Sensors**: Detect forced entry attempts on doors and windows.

TYPES OF SURVEILLANCE AND MONITORING…

- **C. Security Personnel and Monitoring Centres**
  - **Security Operations Center (SOC)**: A centralized unit that monitors security events in real-time.
  - **On-Site Security Teams**: Trained personnel who handle security incidents and provide rapid responses.

3. DISASTER RECOVERY AND CONTINGENCY PLANNING

- Disaster recovery and contingency planning ensure that an organization can recover quickly from security incidents, natural disasters, or cyberattacks.

3. DISASTER RECOVERY AND CONTINGENCY PLANNING…

- **A. Disaster Recovery Plan (DRP)**
  - A disaster recovery plan (DRP) outlines the steps an organization must take to **restore operations** after a disaster or security incident.
- **Key Components of a DRP:**
  1. **Risk Assessment** – Identifying potential threats, such as natural disasters, cyberattacks, and equipment failures.
  2. **Critical Asset Protection** – Determining which infrastructure and systems must be protected.
  3. **Data Backup Strategy** – Regularly backing up critical data and storing copies in secure locations.
  4. **Alternative Power Sources** – Installing backup generators or UPS systems for power outages.
  5. **Emergency Response Team** – Assigning roles and responsibilities for security teams in case of an incident.

3. DISASTER RECOVERY AND CONTINGENCY PLANNING…

- **B. Contingency Planning**
  - Contingency planning involves preparing for unexpected disruptions and ensuring that security measures remain functional.
- **Steps in Contingency Planning:**
  1. **Business Continuity Planning (BCP)**: Ensures essential business operations continue during and after a disaster.
  2. **Incident Response Plan**: Defines how to respond to security breaches, fires, or floods.
  3. **Evacuation Procedures**: Outlines steps to safely evacuate personnel in emergencies.
  4. **Regular Drills and Testing**: Conducting security drills to assess the effectiveness of disaster recovery plans.

KEY COMPONENTS OF ISO 27001

- ISO 27001 consists of two main parts:
  1. ISMS Requirements Clauses
  2. Annex A – Controls & Best Practices

ISMS REQUIREMENT CLAUSES

- The ISO/IEC 27001 Information Security Management System (ISMS) is based on a set of requirement clauses outlined in the standard. These clauses define how an organization should establish, implement, maintain, and continually improve its ISMS.
- ISO 27001:2022 - ISMS Requirement Clauses ISO 27001 consists of 10 main clauses (Clauses 0–10), but only Clauses 4–10 contain mandatory requirements for ISMS implementation.

ISMS REQUIREMENT CLAUSES…

- These are the mandatory requirements for an organization to establish a security management. **(4-10 clauses)**. Clauses 4–10 are mandatory for ISO 27001 certification.

ISMS Requirement Clause	Description
4. Context of the Organization	Identify internal & external issues affecting information security.
5. Leadership	Management must commit to security and assign roles/responsibilities.
6. Planning	Identify security risks and plan how to mitigate them.
7. Support	Ensure availability of resources, staff training, and documentation.
8. Operation	Implement security processes and risk treatment plans.
9. Performance Evaluation	Monitor security performance through audits and assessments.
10. Improvement	Continuously improve security measures based on feedback and incidents.

ISMS REQUIREMENT CLAUSES…

- 0-3 clauses are not mandatory.

ISMS Requirement Clause	Description
0: Introduction	Provides an overview of information security, risk management, and the importance of ISMS.
1: Scope	Defines the applicability of ISO 27001 to any organization, regardless of size or industry.
2: Normative References	Refers to ISO/IEC 27000 as a key reference for terms and definitions.
3: Terms and Definitions	Lists definitions of key ISMS-related terms.

ISO 27001:2022 - ANNEX A CONTROLS

- Annex A of ISO/IEC 27001:2022 provides a structured list of 93 security controls, categorized into 4 main themes.
- These controls help organizations manage information security risks effectively.

ANNEX A - FOUR CONTROL THEMES

Theme	Description	No. of Controls
A.5 - Organizational Controls	Policies, risk management, governance, and compliance.	37
A.6 - People Controls	Security awareness, training, and human resource security.	8
A.7 - Physical Controls	Facility security, access management, and environmental security.	14
A.8 - Technological Controls	IT security, access control, cryptography, and monitoring.	34

A.5 – ORGANIZATIONAL CONTROLS (37 CONTROLS)

- These controls focus on governance, risk management, and compliance.

1. **Information security policies** – Establish and review policies.
2. **Information security roles & responsibilities** – Assign ISMS roles.
3. **Segregation of duties** – Prevent fraud & conflicts of interest.
4. **Management of information security risks** – Identify and assess risks.
5. **Acceptable use of information** – Define rules for IT assets.
6. **Inventory of information assets** – Maintain an asset register.

A.5 – ORGANIZATIONAL CONTROLS (37 CONTROLS)…

7. **Classification of information** – Define confidentiality levels.
8. **Labelling of information** – Ensure classified data is marked.
9. **Handling of information** – Secure transmission & storage.
10. **Access control policy** – Define user access rules.
11. **User access management** – Ensure only authorized access.
12. **Privileged access management** – Protect admin accounts.
13. **Authentication information security** – Enforce strong passwords & MFA.
14. **Supplier relationships** – Ensure third-party security compliance.

A.5 – ORGANIZATIONAL CONTROLS (37 CONTROLS)…

15. **ICT readiness for business continuity** – Ensure IT resilience.
16. **Event logging** – Maintain system logs.
17. **Monitoring activities** – Detect security incidents.
18. **Protection against malware** – Deploy antivirus & threat prevention.
19. **Technical vulnerability management** – Patch and update systems.
20. **Configuration management** – Standardize security settings.
21. **Backup management** – Secure data backups.

A.5 – ORGANIZATIONAL CONTROLS (37 CONTROLS)…

22. **Logging and monitoring** – Detect & respond to incidents.
23. **Cryptographic controls** – Secure data via encryption.
24. **Physical security perimeters** – Define restricted areas.
25. **Secure disposal of information** – Properly destroy sensitive data.
26. **Clear desk & screen policy** – Prevent unauthorized data access.
27. **Information transfer security** – Secure data transfers.
28. **Security requirements for cloud services** – Protect cloud data.
29. **Data masking** – Conceal sensitive data.

A.5 – ORGANIZATIONAL CONTROLS (37 CONTROLS)…

30. **Threat intelligence** – Monitor cyber threats.
31. **Secure coding principles** – Ensure software security.
32. **Data leakage prevention** – Protect against data loss.
33. **Security awareness and training** – Educate employees.
34. **Remote working security** – Secure remote connections.
35. **Secure software development** – Integrate security into SDLC.
36. **Incident response planning** – Establish an incident response framework.
37. **Compliance with legal, regulatory, and contractual requirements** – Maintain compliance.

A.6 – PEOPLE CONTROLS (8 CONTROLS)

- These controls focus on security awareness, responsibilities, and HR management.

---

1. **Screening of employees** – Background checks before hiring.
2. **Terms & conditions of employment** – Define security responsibilities.
3. **Security awareness training** – Conduct periodic training.
4. **Disciplinary process** – Address security violations.
5. **Responsibilities after employment** – Remove access rights when employees leave.
6. **Confidentiality agreements** – Ensure employees sign NDAs.
7. **Secure handling of sensitive information** – Prevent leaks.
8. **Reporting security weaknesses** – Encourage incident reporting.

A.7 – PHYSICAL CONTROLS (14 CONTROLS)

- These controls focus on securing physical infrastructure and access.

1. **Physical security perimeter** – Restrict access to sensitive areas.
2. **Physical entry controls** – Implement key cards or biometrics.
3. **Securing offices, rooms & facilities** – Prevent unauthorized entry.
4. **Protecting against environmental threats** – Mitigate fire, floods, etc.
5. **Working in secure areas** – Restrict access to critical zones.
6. **Visitor management** – Log and control visitor access.
7. **Clear desk and screen policy** – Prevent unauthorized viewing.

A.7 – PHYSICAL CONTROLS (14 CONTROLS)…

8. **Physical protection of IT infrastructure** – Secure data centers.
9. **Equipment maintenance** – Ensure reliable IT hardware.
10. **Secure disposal of assets** – Destroy old devices securely.
11. **Protection of unattended equipment** – Lock workstations.
12. **Cabling security** – Secure network cables.
13. **Secure storage media** – Encrypt and protect removable storage.
14. **Environmental controls** – Manage temperature, power, and fire protection.

A.8 – TECHNOLOGICAL CONTROLS (34 CONTROLS)

- These controls focus on securing IT systems and networks.

---

1. **Endpoint device security** – Secure laptops, mobile devices.
2. **User authentication** – Implement MFA (multi-factor authentication).
3. **Privileged access control** – Restrict high-level accounts.
4. **Network security** – Protect against cyber threats.
5. **Firewalls & intrusion detection** – Monitor unauthorized activities.
6. **Secure configuration** – Harden system settings.
7. **Patch management** – Regular software updates.

A.8 – TECHNOLOGICAL CONTROLS (34 CONTROLS)…

8. **Logging & monitoring** – Track security events.
9. **Secure system development** – Apply secure coding practices.
10. **Access control for applications** – Restrict app usage.
11. **Data encryption** – Protect sensitive information.
12. **Data masking & anonymization** – Conceal personal data.
13. **Anti-malware protection** – Deploy antivirus & threat detection.
14. **Secure cloud computing** – Protect cloud assets.
15. **Security testing & evaluation** – Conduct vulnerability testing.

A.8 – TECHNOLOGICAL CONTROLS (34 CONTROLS)…

16. **Secure API management** – Protect API integrations.
17. **Mobile device security** – Secure BYOD policies.
18. **IoT security** – Protect smart devices.
19. **Secure backup & recovery** – Maintain data redundancy.
20. **Zero Trust Architecture** – Verify every access attempt.
21. **DDoS protection** – Prevent denial-of-service attacks.
22. **AI & automation security** – Ensure AI-based decision integrity.
23. **Security operations center (SOC)** – Centralized monitoring.
24. **Threat intelligence & hunting** – Proactively detect threats.

A.8 – TECHNOLOGICAL CONTROLS (34 CONTROLS)…

25. **Forensics & incident response** – Investigate security incidents.
26. **Data integrity monitoring** – Prevent unauthorized changes.
27. **Secure disposal of digital assets** – Wipe old data securely.
28. **Insider threat detection** – Monitor internal risks.
29. **Security of test environments** – Prevent leaks from development data.
30. **Cloud access security brokers (CASB)** – Control cloud applications.

A.8 – TECHNOLOGICAL CONTROLS (34 CONTROLS)…

31. **Blockchain security** – Protect distributed ledgers.

32. **Continuous security monitoring** – 24/7 protection.

33. **Secure DevOps (DevSecOps)** – Integrate security in development.

34. **Secure AI models** – Protect machine learning models.

PYTHON PROGRAM TO DEMONSTRATE BASIC SECURITY MANAGEMENT PRACTICES BASED ON THE ISO 27001 FRAMEWORK

- The program includes:
  - User authentication (Access Control)
  - Password hashing (Cryptography)
  - Role-based access control (RBAC))
  - Logging security events
  - Incident response simulation

PYTHON PROGRAM TO DEMONSTRATE BASIC SECURITY MANAGEMENT PRACTICES BASED ON THE ISO 27001 FRAMEWORK…

- The program will simulate a secure login system with the following features:
- **User authentication** – Uses hashed passwords (SHA-256).
- **Access Control (RBAC)** – Admins, Employees, and Auditors have different levels of access.
- **Security Logging** – Records login attempts and security events to a log file.
- **Incident Response** – Logs failed login attempts for threat monitoring

import hashlib
import datetime

Dictionary to store user credentials (hashed passwords) and roles

users_db = {
"admin": {"password": hashlib.sha256("Admin@123".encode()).hexdigest(), "role": "Admin"},
"user1": {"password": hashlib.sha256("User@123".encode()).hexdigest(), "role": "Employee"},
"auditor": {"password": hashlib.sha256("Audit@123".encode()).hexdigest(), "role": "Auditor"}
}

Security log file

```
LOG_FILE = "security_log.txt“
def log_security_event(event):    """ Logs security events to a file """
with open(LOG_FILE, "a") as file:
    timestamp = datetime.datetime.now().strftime("%Y-%m-%d %H:%M:%S")
    file.write(f"[{timestamp}] {event}\n")
```

```
def authenticate_user(username, password):
#Authenticates user using SHA-256 hashed passwords
hashed_password = hashlib.sha256(password.encode()).hexdigest()
if username in users_db and users_db[username]["password"] == hashed_password:
    log_security_event(f"User '{username}' successfully logged in.")
    return users_db[username]["role"]
else:
    log_security_event(f"Failed login attempt for user '{username}'. Potential security breach!")
    return None
```

```
def access_control(role):
#Simulates role-based access control
if role == "Admin":
print("Access granted: Admin Panel - You can manage system security settings.")
elif role == "Employee":
    print("Access granted: Employee Dashboard - You can view your profile.")
elif role == "Auditor":
    print("Access granted: Audit Logs - You can review security logs.")
else:
    print("Access Denied: Unauthorized access attempt detected.")
    log_security_event("Unauthorized access attempt detected.")
```

```
# Simulated login system
def main():
    print("Secure Access System ")
    username = input("Enter username: ")
    password = input("Enter password: ")

    role = authenticate_user(username, password)

    if role:
        access_control(role)
    else:
        print("Authentication failed! Incident logged.")
if __name__ == "__main__":
main()
```

RUN THE CODE

- Enter a valid username (admin, user1, or auditor) and the corresponding password.
- If authentication succeeds, the user gets access based on their role.
- If authentication fails, an incident is logged in ***security_log.txt.***

WHAT HAVE WE ACHIEVED?

- ISO 27001 security controls has demonstrated:
  - **Access Control** – Role-based access restrictions to ensure only authorized users can access sensitive information.
  - **Cryptography** – Passwords are securely stored using cryptographic hashing (e.g., SHA-256) to prevent unauthorized access.
  - **Operations Security** – Security event logging is employed to monitor user activities, detect unusual behaviour, and ensure the integrity of the system.
  - **Incident Response**– Unauthorized login attempts are recorded to detect potential breaches and to ensure prompt incident response for further investigation.

WHAT IS HASHING?

- Hashing is the process of converting data (such as a password or file) into a fixed-length string or a different value using a mathematical algorithm.
- Hashing ensure data integrity, authentication, and secure storage
- It is one-way and irreversible, meaning you cannot convert the hash back into the original data.
- Used in cryptographic security applications.

```
_id: ObjectId('67b03a4505e92a4733ac8d76')
firstName : "Leah"
lastName : "Nanyangwe"
username : "leah.nanyangwe.3891"
email : "nanyangweleah@gmail.com"
phoneNumber : "0967203891"
organization : "Chambeshi Water Supply and Sanitation Company Ltd"
country : "Zambia"
password : "$2b$10$nvdS9a9A0AS1tONcw/3HF.xgj9TGWbyMyOR0USywN5Sd4/PSyiH5a"
isAgreed : true
```

WHY USE HASHING?

- **Ensures data integrity:**
  - Hashing ensures that files/data are not tampered with.
- **Protects passwords:**
  - Instead of storing plain-text passwords, systems store hashed passwords.
  - Even if an attacker accesses the database, they cannot retrieve the original password.

HOW THIS WORKS

1. **Password Hashing:**
   - The hash_password() function converts plaintext passwords into SHA-256 hashes before storing them.
   - Example: "admin123" is stored as

     f7846f55cf23d82f75a6e2e3ef44b8f60b17a0cdbf6e1c252f18942fbb36c8c1

2. **Authentication with Hashed Passwords:**
   - When a user enters a password, it is hashed and compared to the stored hash.
   - If the hashes match, the user is authenticated.
3. **Logging Unauthorized Attempts:**
   - If a user enters the wrong password, the system logs a security warning.

```
import bcrypt from "bcryptjs";
```

```
const hashedPassword = await bcrypt.hash(password, 10);
const result = await collection.insertOne({
  firstName,
  lastName,
  username,
  email: email.toLowerCase(),
  phoneNumber,
  organization,
  country,
  password: hashedPassword,
  isAgreed,
  createdAt: new Date(),
});
```

SHA-256 (SECURE HASH ALGORITHM - 256 BIT)

- SHA-256 is a cryptographic hash function that converts input data into a fixed 256-bit (32-byte) hash value.
- It is part of the SHA-2 family, developed by the National Security Agency (NSA) and published by the National Institute of Standards and Technology (NIST).

KEY FEATURES OF SHA-256

- **Fixed-Length Output:**
  - No matter the input size, SHA-256 always produces a 64-character hexadecimal hash (256 bits).
- **One-Way Function:**
  - The hash cannot be reversed to get the original input.
- **Avalanche Effect:**
  - A small change in input drastically changes the hash.
  - Example:

SHA-256("Hello") = 185f8db32271fe25f561a6fc938b2e264306ec304eda518007d1764826381969

KEY FEATURES OF SHA-256…

- **Collision Resistance:**
  - No two different inputs should generate the same hash.
- **Used in Cryptographic Applications:**
  - Blockchain (Bitcoin, Ethereum)
  - Password hashing
  - Digital signatures and certificates
  - Data integrity verification

HOW SHA-256 WORKS

- **Pre-Processing:**
  - The input message is padded to ensure its length is a multiple of 512 bits.
- **Message Breakdown:**
  - The message is split into 512-bit blocks.
- **Compression Function:**
  - Uses bitwise operations, modular addition, and logical functions to transform data.
- **Final Hash Output:**
  - A unique 256-bit (64 hex characters) hash is generated.

```
import hashlib
import datetime
```

```
# Function to hash a password using SHA-256
def hash_password(password):
    hashed = hashlib.sha256(password.encode()).hexdigest()
    return hashed
```

```
# Storing user credentials (hashed passwords) and roles
users_db = {
    "admin": {"password": hash_password("Admin@123"), "role":
"Admin"},
    "user1": {"password": hash_password("User@123"), "role":
"Employee"},
    "auditor": {"password": hash_password("Audit@123"), "role":
"Auditor"}
}
```

```
# Security log file
LOG_FILE = "security_log.txt"

def log_security_event(event):
    #Logs security events to a file
    with open(LOG_FILE, "a") as file:
        timestamp = datetime.datetime.now().strftime("%Y-%m-
%d %H:%M:%S")
        file.write(f"[{timestamp}] {event}\n")
```

```
def authenticate_user(username, password):
    #Authenticates user using SHA-256 hashed passwords

    # Hash the entered password
    entered_hashed_password = hash_password(password)

    # Show visible demonstration of hashing
    print("\nHashing Demonstration")
    print(f"Entered Password: {password}")
    print(f"Entered Hashed Password:
{entered_hashed_password}")

    if username in users_db:
        stored_hashed_password =
users_db[username]["password"]

        print(f"Stored Hashed Password:
{stored_hashed_password}")
```

```
 # Compare entered hash with stored hash
        if entered_hashed_password ==
stored_hashed_password:
            log_security_event(f"User '{username}' successfully
logged in.")
            print("\nAuthentication successful!\n")
            return users_db[username]["role"]
        else:
            log_security_event(f"Failed login attempt for user
'{username}'. Potential security breach!")
            print("\nAuthentication failed! Hashes do not
match.\n")
            return None
    else:
        log_security_event(f"Failed login attempt for unknown
user '{username}'.")
        print("\nAuthentication failed! User not found.\n")
        return None
```

```
def access_control(role):
    #Simulates role-based access control
    if role == "Admin":
        print("Access granted: Admin Panel - You can manage
system security settings.")
    elif role == "Employee":
        print("Access granted: Employee Dashboard - You can
view your profile.")
    elif role == "Auditor":
        print("Access granted: Audit Logs - You can review
security logs.")
    else:
        print("Access Denied: Unauthorized access attempt
detected.")
        log_security_event("Unauthorized access attempt
detected.")
```

```
# Simulated login system
def main():
    print("Secure Access System")
    username = input("Enter username: ")
    password = input("Enter password: ")

    role = authenticate_user(username, password)

    if role:
        access_control(role)
    else:
        print("Authentication failed! Incident logged.")

if __name__ == "__main__":
    main()
```

RISK MANAGEMENT

- The process of taking actions to assess risks and avoid or reduce risk to acceptable levels.

RISK

- The probability of suffering harm or loss. It refers to an action, event or a natural occurrence that could cause an undesirable outcome, resulting in a negative impact or consequence.

STEPS IN RISK MANAGEMENT

- Risk Assessment
- Risk Mitigation
- Evaluation

RISK ASSESSMENT

- The process of identifying threats to information or information systems, determining the likelihood of occurrence of the threat, and identifying system vulnerabilities that could be exploited by the threat.
- Risk assessment is the first phase in the risk management process.

RISK ASSESSMENT

- Classify information
- Identify threats
- Identify vulnerabilities
- Analyse risk to information assets
- Select a method
- Summarise and communicate risk

CLASSIFY INFORMATION

- Before an organization can assess the risk, it must first classify the information assets in the organization.
- Classification is the designation given to information from a defined category on the basis of its sensitivity.
- Information assets include all categories of information (automated and nonautomated), including (but not limited to) data contained in records, files, and databases.

CLASSIFY INFORMATION

- Information assets usually include: public records mission-critical systems, customer interfaces, internal tools, source code, and confidential records.
- The organization is responsible for protecting the confidentiality, integrity and availability of the information assets.
- The value of an asset will be determined by the information owner - an individual or a group of individuals responsible for making classification and control decisions regarding use of information.

IDENTIFY THREATS

- A threat is a force, organization or person, which seeks to gain access to, or compromise, information.
- By looking at the nature of the threat, its capability and resources, one can assess it, and then determine the likelihood of occurrence, as in risk assessment.
- A threat can be assessed in terms of the probability of an attack.

IDENTIFY THREATS

- A threat is a force, organization or person, which seeks to gain access to, or compromise, information.
- By looking at the nature of the threat, its capability and resources, one can assess it, and then determine the likelihood of occurrence, as in risk assessment.
- A threat can be assessed in terms of the probability of an attack.

IDENTIFY THREATS…

- It is important to be aware of threats to your organization's information in order to prevent compromise to that information's confidentiality, integrity and availability.
- Information security threats must be identified at as many levels as possible.

THERE ARE MANY TYPES OF INFORMATION SECURITY THREATS, SOME EXAMPLES ARE LISTED BELOW:

- Internal (e.g., malicious or unaware employees)
- Mobile (e.g., attackers who steal remote systems which, in turn, provide access to information)
- Physical (e.g., attackers who steal computers or enter server rooms, file cabinets, or offices)
- Natural (e.g., fire, floods, and earthquakes resulting in electrical outages, equipment and hardware failures)

THERE ARE MANY TYPES OF INFORMATION SECURITY THREATS, SOME EXAMPLES ARE LISTED BELOW:

- Network (e.g., attackers who try to compromise systems exposed on a public network or try to spoof or imitate remote systems)
- Social (e.g., attackers who try to fool employees into revealing information through phishing)
- Malicious (e.g., viruses, worms, and Trojan horses, code that may damage, reveal, or capture information).

IDENTIFY VULNERABILITIES

- Vulnerabilities must be identified.
- Vulnerabilities are weaknesses, in a system or facility holding information, which can be exploited to gain access or violate system integrity.

VULNERABILITIES CAN BE ASSESSED IN TERMS OF THE MEANS BY WHICH THE ATTACK WOULD BE SUCCESSFUL, SUCH AS:

- Tapes lost during transfer to a storage facility (availability issue).
- Information read by an unauthorized individual(s) (confidentiality issue).
- Software and hardware not maintained at current patch levels allow unauthorized access via the Internet resulting in a breach of confidential information (confidentiality, integrity and/or availability issues).
- Unintentional loss of data via theft resulting in identity theft (confidentiality issue).
- Accidental or intentional deletion or modification of information (availability and integrity issues).
- Unsecured computers and portable devices such as blackberries, laptops, or USB devices (confidentiality, integrity and availability issues).

ANALYZE RISK TO INFORMATION ASSETS

- There are inherent risks involved in containing and transferring information.
- Information is subject to intentional and unintentional actions by other people or systems.
- If information is confidential, there may be unauthorized people who want to see it, such as competitors or disgruntled or curious employees.
- People may try to break into the devices containing the information or try to intercept the information during transfer.

ANALYZE RISK TO INFORMATION ASSETS…

- People may also receive confidential information unknowingly and completely by accident.
- Information systems can be maliciously or accidentally damaged.
- Information security breaches like these can seriously hurt an organization.

RISK FOR A GIVEN ASSET CAN BE PROVIDED IN THE MOST GENERAL FORM USING THE FOLLOWING EQUATION:

Risk = (Probability of a threat occurring against an asset) x (Value of asset)

- The higher the likelihood of a threat occurring and affecting an asset and the higher the value of that asset, the higher the risk.
- If a threat has little or no chance of occurring, or if the asset has no value, the risk is either very low or zero.
- Since information assets within an organization most likely hold some level of value, risk management will involve reducing the likelihood of threats from occurring.

ANALYZE RISKS

- specify likelihood of occurrence of each identified threat to asset given existing controls
  - management, operational, technical processes and procedures to reduce exposure of org to some risks
- specify consequence should threat occur
- hence derive overall risk rating for each threat

  risk = probability threat occurs x cost to organization
- in practice very hard to determine exactly
- use qualitative not quantitative, ratings for each
- aim to order resulting risks in order to treat them

DETERMINE LIKELIHOOD

Rating	Likelihood Description	Expanded Definition
1	**Rare**	May occur only in exceptional circumstances and may deemed as “unlucky” or very unlikely.
2	**Unlikely**	Could occur at some time but not expected given current controls, circumstances, and recent events.
3	**Possible**	Might occur at some time, but just as likely as not. It may be difficult to control its occurrence due to external influences.
4	**Likely**	Will probably occur in some circumstance and one should not be surprised if it occurred.
5	**Almost Certain**	Is expected to occur in most circumstances and certainly sooner or later.

DETERMINE CONSEQUENCE

Rating	Consequence	Expanded Definition
1	**Insignificant**	Generally a result of a minor security breach in a single area. Impact is likely to last less than several days and requires only minor expenditure to rectify.
2	**Minor**	Result of a security breach in one or two areas. Impact is likely to last less than a week, but can be dealt with at the segment or project level without management intervention. Can generally be rectified within project or team resources.
3	**Moderate**	Limited systemic (and possibly ongoing) security breaches. Impact is likely to last ***up to 2 weeks*** and generally requires management intervention. Will have ongoing compliance costs to overcome.
4	**Major**	Ongoing systemic security breach. Impact will likely last ***4-8 weeks*** and require significant management intervention and resources to overcome, and compliance costs are expected to be substantial. Loss of business or organizational outcomes is possible, but not expected, especially if this is a once off.
5	**Catastrophic**	Major systemic security breach. Impact will last for ***3 months or more*** and senior management will be required to intervene for the duration of the event to overcome shortcomings. Compliance costs are expected to be very substantial. Substantial public or political debate about, and loss of confidence in, the organization is likely. Possible criminal or disciplinary action is likely.
6	**Doomsday**	Multiple instances of major systemic security breaches. Impact duration cannot be determined and senior management will be required to place the company under voluntary administration or other form of major restructuring. Criminal proceedings against senior management is expected, and substantial loss of business and failure to meet organizational objectives is unavoidable.

DETERMINE RESULTANT RISK

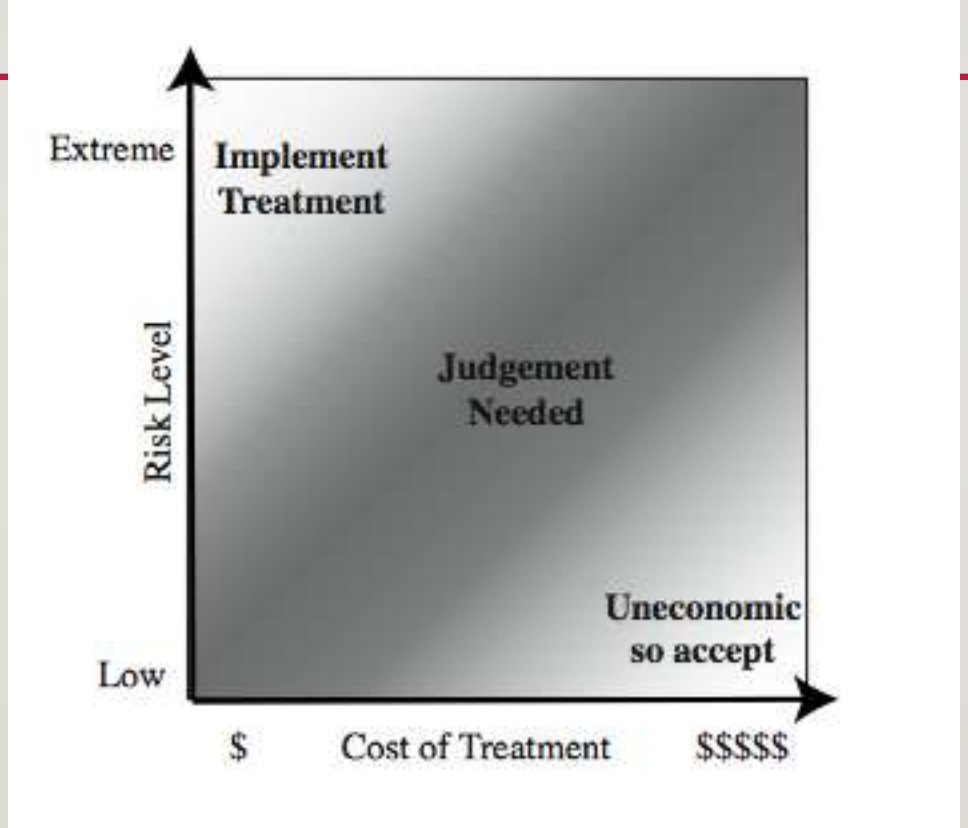
	Consequences					
Likelihood	**Doomsday**	**Catastrophic**	**Major**	**Moderate**	**Minor**	**Insignificant**
Almost Certain	E	E	E	E	H	H
Likely	E	E	E	H	H	M
Possible	E	E	E	H	M	L
Unlikely	E	E	H	M	L	L
Rare	E	H	H	M	L	L

Risk Level	Description
Extreme (E)	Will require detailed r esearch and management planning at an executive/director level. Ongoing planning and monitoring will be required with regular reviews. Substantial adjustment of controls to manage the risk are expected, with costs possibly exceeding original forecasts.
High (H)	Requires management attention, but management and planning can be left to senior project or team leaders. Ongoing planning and monitoring with regular reviews are likely, though adjustment of controls are likely to be met from within existing resources
Medium (M)	Can be managed by existing specific monitoring and response procedures. Management by employees is suitable with appropriate monitoring and reviews.
Low (L)	Can be managed through routine procedures.

DOCUMENT IN RISK REGISTER AND EVALUATE RISKS

Asset	Threat/ Vulnerability	Existing Controls	Likelihood	Consequence	Level of Risk	Risk Priority
Internet Router	Outside Hacker attack	Admin password only	Possible	Moderate	High	1
Destruction of Data Center	Accidental Fire or Flood	None (no disaster recovery plan)	Unlikely	Major	High	2

RISK TREATMENT



RISK TREATMENT ALTERNATIVES

- **risk acceptance**: *accept risk (perhaps because of excessive cost of risk treatment)*
- **risk avoidance**: *do not proceed with the activity that causes the risk (loss of convenience)*
- **risk transfer**: buy insurance; outsource
- **reduce consequence**: *modify the uses of an asset to reduce risk impact (e.g., offsite backup)*
- **reduce likelihood**: *implement suitable controls*

CASE STUDY: SILVER STAR MINES

- fictional operation of global mining company
- large IT infrastructure
  - both common and specific software
  - some directly relates to health & safety
  - formerly isolated systems now networked
- decided on combined approach
- mining industry less risky end of spectrum
- management accepts moderate or low risk

ASSETS

- reliability and integrity of SCADA nodes and net
- integrity of stored file and database information
- availability, integrity of financial system
- availability, integrity of procurement system
- availability, integrity of maintenance/production system
- availability, integrity and confidentiality of mail services

THREATS & VULNERABILITIES

- unauthorized modification of control system
- corruption, theft, loss of info
- attacks/errors affecting procurement system
- attacks/errors affecting financial system
- attacks/errors affecting mail system
- attacks/errors maintenance/production affecting system

RISK REGISTER

Asset	Threat/ Vulnerability	Existing Controls	Likelihood	Consequence	Level of Risk	Risk Priority
Reliability and integrity of the SCADA nodes and network	Unauthorized modification of control system	layered firewalls & servers	Rare	Major	High	1
Integrity of stored file and database information	Corruption, theft, loss of info	firewall, policies	Possible	Major	Extreme	2
Availability and integrity of Financial System	Attacks/errors affecting system	firewall, policies	Possible	Moderate	High	3
Availability and integrity of Procurement System	Attacks/errors affecting system	firewall, policies	Possible	Moderate	High	4
Availability and integrity of Maintenance/ Production System	Attacks/errors affecting system	firewall, policies	Possible	Minor	Medium	5
Availability, integrity and confidentiality of mail services	Attacks/errors affecting system	firewall, ext mail gateway	Almost Certain	Minor	High	6

SUMMARY

- detailed need to perform risk assessment as part of IT security management process
- relevant security standards
- presented risk assessment alternatives
- detailed risk assessment process involves
  - context including asset identification
  - identify threats, vulnerabilities, risks
  - analyse and evaluate risks
- Silver Star Mines case study

SELECT A METHOD

- In order to quantify a risk, an organization will need to develop a method of measuring risk so that this information can be communicated with others.
- The question “What information assets are most at risk to compromise or damage and what can happen to these assets?” needs to be answered.
- The question may best be answered by assigning a value and acceptable risk level to each asset.

SELECT A METHOD…

- The value of an asset varies from asset to asset and from organization to organization.
- The level of risk depends on actions taken by the organization.
  - For example, if backups are done and secured, the loss (unavailability) of an electronic copy may be a low risk.

EXAMPLE: MEASURING A RISK

Information Asset	**Value** (High/Low/Medium)	**Risk Level** (High/Low/Medium)	**Notes** (explain major risks and or costs)
Board Minutes	High	Low	Expectation is these are highly protected
Personnel Records	High	High (Identity Theft)	Have a high value to the organization for reporting, retiring, payroll, etc.

SELECT A METHOD…

- Most organizations make information security risk assessment decisions by asking some questions based on confidentiality, integrity and availability.

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

1. NEGATIVE EFFECTS ON CREDIBILITY

- Will an organization's actions, process, program or procedure negatively affect its credibility?
  - Imagine if health information, probation or social services information were posted publicly on the Internet. (Confidentiality)

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

2. HEALTH, WELFARE AND DETRIMENT TO THE COMMUNITY

- Will an organization's actions, process, program or procedure affect the health, safety and welfare of another?
  - If information is corrupted, drug-testing results for school bus drivers changed, bridge height specifications altered, or a computer system slowdown delays updated information about a stolen car from reaching law enforcement, citizens' health and safety may be at risk. (Availability)

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

3. VIOLATION OF THE RIGHT TO INFORMATIONAL PRIVACY OR CONFIDENTIALITY

- Will an organization's actions, process, program or procedure result in the breach of informational privacy or confidentiality?
  - If unauthorized release of personal information, Social Security number, health information, drug testing results, etc. occurs, it may result in identity theft.

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

4. ACCESSIBILITY AND INTEGRITY OF PUBLIC RECORDS

- Will an organization's actions, process, program or procedure prevent access to necessary records or result in changes to data in them?
  - If vital records are stored on a computer but are not backed up and a natural disaster destroys the computer, the records are no longer available.
  - If tax records are accessed by an unauthorized individual, the records could be modified and the integrity of the information lost.

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

5. VIOLATION OF LAWS, REGULATIONS OR CONTRACTS

- Will an organization's actions, process, program or procedure result in the breach of any law, regulation or contract?
  - If a breach of information occurs, for example where a law is in place, the result may be: "if client information is exposed or divulged inappropriately, individuals can be financially accountable with personal financial liability upwards of $5,000."

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

6. OPERATIONAL IMPACT

- Will an organization's actions, process, program or procedure result in impacting operations in a negative way?
  - If systems are unavailable, information systems crash, or email is not available, chaos can ensue, or, at best, jobs cannot be completed.

SOME OF THE INFORMATION RISK ASSESSMENT QUESTIONS ASKED ARE AS FOLLOWS:

7. FINANCIAL CONSEQUENCES

- Will an organization's actions, process, program or procedure result in the loss of revenue, workforce downtime, litigation, or increased resource expenditure?
  - If information is destroyed due to a virus or catastrophe, how could it be restored? What is the cost to reproduce or recreate it?

ADDITIONAL QUESTIONS THAT MAY BE ASKED DURING A RISK ASSESSMENT INCLUDE:

- Who has a need to access this information?
- What happens if the application, program, or website is not available to those who need the information?
- Are there any security risks associated with the proposed software?
- To whom or what other organizations will this information be connected?
- Will this information be connected to the Internet?

SUMMARIZE AND COMMUNICATE RISK

- Risk has to be measured for each information asset, and for the organization as a whole, and then communicated so decisions can be made to manage the risk.